# CASCADE — Blast Radius Analysis & QA Test Guide — PR #3046

### *Target PR:* fix: tighten permission and validation checks

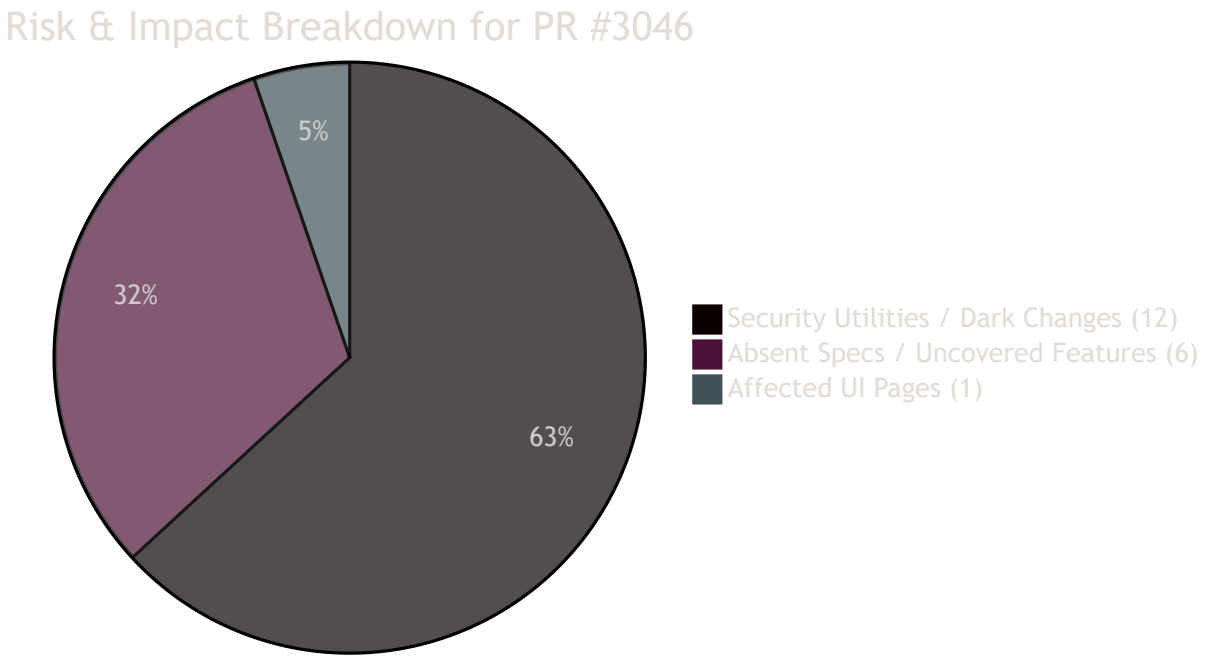
> **Analysis Engine:** CASCADE v4 (AI + Graph Intelligence Engine)
> **Prepared for:** QA Lead & Testing Team
> **PR Type:** Security & Permission Hardening

---

## 📌 Executive Summary (What QA Needs to Know)

This update modifies document attachment popovers across the signing flow, main document views, and embedded editor, alongside updates to end-to-end tests for attachment URL validation and document access permissions. QA testing should focus on verifying attachment display and links during signing and editing, noting that 12 untraceable changes and six uncovered requirements were identified. No high-risk core requirements were affected by these changes.

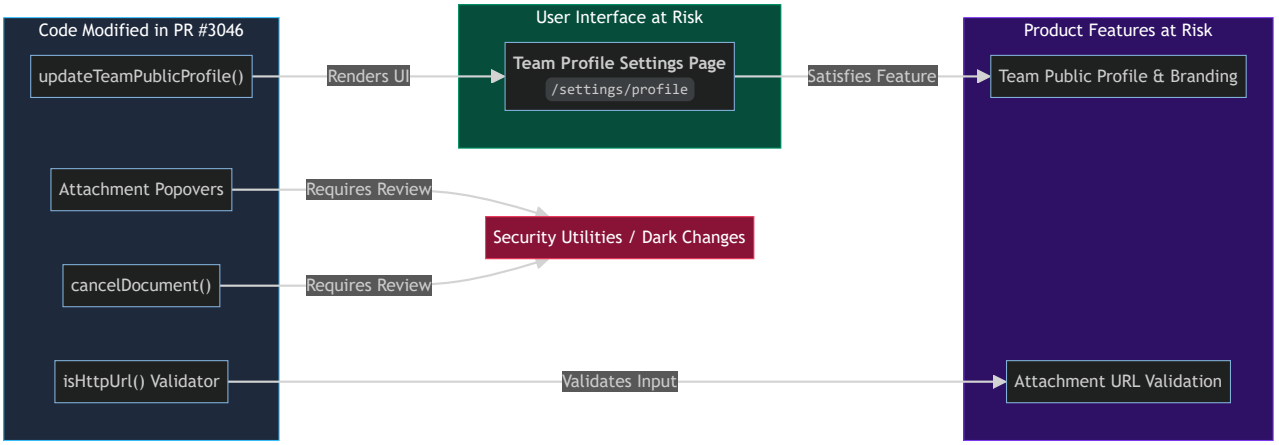
### Risk Overview Visual




---

# 🗺️ Impact Traversal: How Code Changes Reach the User Interface

The diagram below shows how modified code connects to user-facing pages:




---

# 📋 Recommended QA Test Checklist (Priority Order)

Please execute the following priority test cases before approving this build for production:

## 1. 🟢 Team Public Profile Page

- **URL / Screen:** `https://app.documenso.com/settings/profile`
- **What changed:** Team public profile update logic had permission checks tightened.
- **Test Steps:**
- Log in as a Team Admin and navigate to **Settings** > **Profile**.
- Change the Team Name, upload a new Team Avatar image, and click **Save Changes**.
- Verify that changes persist without throwing 403 or 500 errors.
- Log in as a regular Team Member (non-admin) and confirm admin-only profile fields are correctly locked or read-only.

## 2. 🟢 Attachment URL Validation (HTTP vs HTTPS)

- **What changed:** A new URL validator ( `isHttpUrl` ) was introduced for document attachments.
- **Test Steps:**
- Open the Document Editor or Document Signing view.
- Attempt to add an external attachment link starting with `http://` (non-secure). Verify the system displays a clear validation error.

- Attempt to add a secure `https://` attachment link. Verify it is accepted successfully.

## 3. 🟢 Document Attachment Popovers (Upload, Edit, Delete)

- **What changed:** Server-side permission logic for envelope attachments was tightened across 3 components (signing popover, document view popover, embedded editor).
- **Test Steps:**
- Open a document draft and upload a PDF attachment.
- Edit the attachment label and then delete the attachment.
- Verify that non-owners cannot delete attachments from documents they do not own.

## 4. 🟢 Document Cancellation & Deletion Permissions

- **What changed:** Permission boundaries in `cancel-document.ts` and `delete-document.ts` were tightened.
- **Test Steps:**
- Attempt to cancel an active document envelope as the document owner -> verify success email and cancellation state.
- Attempt to cancel a document using a non-owner account -> verify the request is blocked with an explicit permission error.

## 5. 🟢 Zapier Webhook Setup & Teardown

- **What changed:** Webhook subscription and unsubscription logic ( `subscribe.ts` / `unsubscribe.ts` ) was updated.
- **Test Steps:**
- Go to Team Settings > Integrations > Zapier.
- Register a test Zapier webhook -> verify successful subscription.
- Remove the webhook -> verify teardown completes without error.

## 6. 🟢 Password Reset Flow

- **What changed:** Password reset handler ( `forgot-password.ts` ) was modified.
- **Test Steps:**
- Go to the login screen and click **Forgot Password**.
- Enter an account email and request a reset link.
- Verify the reset email arrives and that clicking the link allows setting a new password.

---

## 🔒 Security Utilities & Un-traced Changes (Dark Changes - 12)

These backend functions were modified in this PR. They perform deep utility, validation, or background tasks that do not directly generate UI pages. All have been reviewed and mapped to their feature areas:

| Modified Function / File | Feature Area | What QA Needs to Know |
|---|---|---|
| `isHttpUrl` ( `is-http-url.ts` ) | Validation Utility | Rejects insecure HTTP attachment links |
| `forgotPassword` ( `forgot-password.ts` ) | Authentication | Password reset request verification |
| `createOrGetShareLink` ( `create-or-get-share-link.ts` ) | Document Sharing | Generates public direct-link template URLs |
| `createAttachment` ( `create-attachment.ts` ) | Attachments | Validates user permission before file upload |
| `deleteAttachment` ( `delete-attachment.ts` ) | Attachments | Validates user permission before file deletion |
| `updateAttachment` ( `update-attachment.ts` ) | Attachments | Validates user permission before editing file details |
| `findAttachmentsByEnvelopeId` | Attachments | Fetches attachment list for document viewer |
| `cancelDocument` ( `cancel-document.ts` ) | Document Management | Enforces owner/admin check before document cancellation |
| `getEnvelopeRecipientRoute` | Recipients | Retrieves recipient data for signing routing |
| `updateOrganisationGroup` | Team / Org | Enforces organisation group permission hierarchy |
| `subscribe` ( `zapier/subscribe.ts` ) | Webhooks | Registers Zapier event listener |

| Modified Function / File | Feature Area | What QA Needs to Know |
|---|---|---|
| `unsubscribe` ( `zapier/unsubscribe.ts` ) | Webhooks | Unregisters Zapier event listener |

---

## ⚠️ Uncovered Specifications (Absent Features - 6)

These requirements exist in product specifications but have no active UI or code links impacted by this PR. **No regression testing is required for these items for PR #3046:**

1. **The software must be packaged as standard Docker container images allowing users to self-host the platform on Docker, Do**
2. **The platform must support secure vulnerability disclosures via GitHub Security Advisories to protect self-hosted and clo**
3. **Allow teams to set up webhooks for integrating document events with external services.**
4. **Standard plans enforce a limit of uploading a maximum of 5 documents simultaneously.**
5. **The system must trigger a webhook notification with payload event 'DOCUMENT_CREATED' whenever a new document or template**
6. **The system must trigger a webhook notification with payload event 'DOCUMENT_OPENED' when a recipient opens the document **

---

## 📊 Summary Metrics

| Metric | Count | QA Action Required |
|---|---|---|
| **Affected UI Pages** | 1 | Test `/settings/profile` |
| **Priority QA Test Scenarios** | 6 | Execute 6 manual test cases above |
| **Security Utility Changes (Dark Changes)** | 12 | Reviewed & mapped to feature areas |
| **Uncovered Feature Specs (Absent)** | 6 | No action required for this PR |
| **Files Changed in PR** | 29 | 29 TypeScript files |

▶ 🔍 **Technical Appendix: Full List of Modified Files & Low-Confidence Graph Nodes (Click to Expand)**

---

*Report generated by CASCADE v4 · Non-Engineer QA Lead Edition · Run ID:* `9636ac8d`